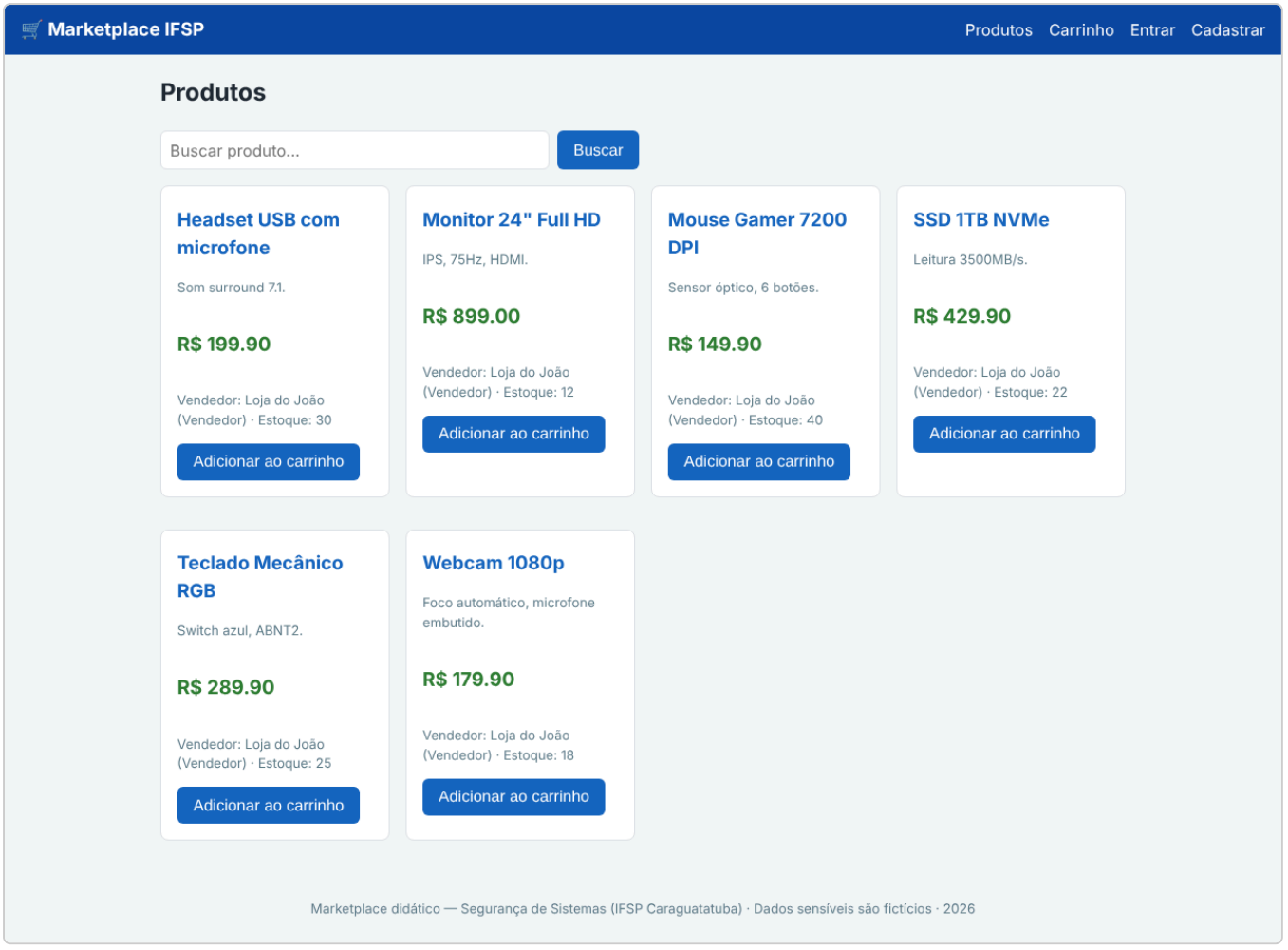
# Evidências / Prints do Marketplace

Segurança de Sistemas — IFSP Caraguatatuba. Nome de guerra: **TutisTutis**. Dados sensíveis são fictícios. Seções 1 e 2 = sistema em modo seguro (OWASP); seção 3 = modo vulnerável ligado por flags, para demonstrar os ataques.

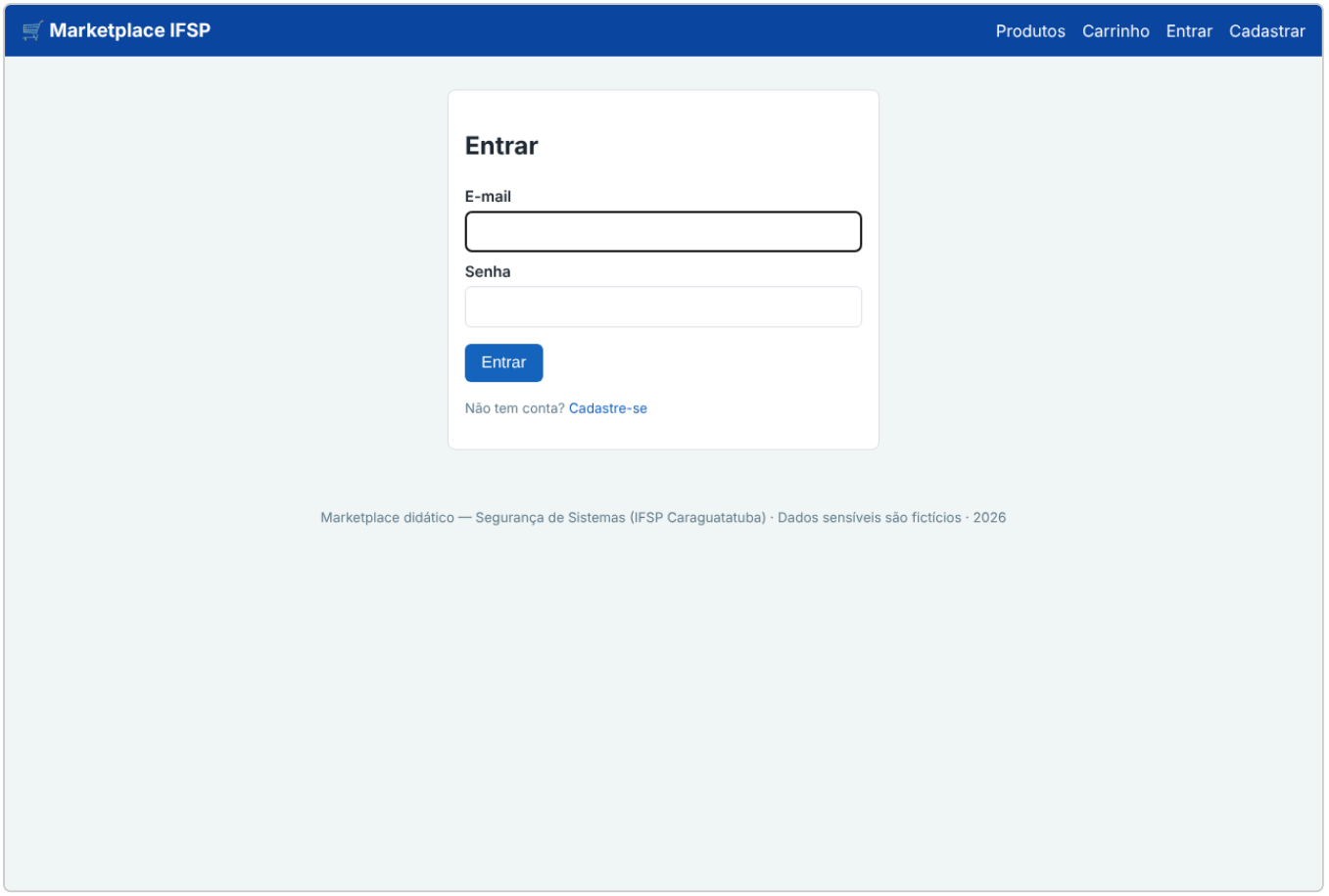
## 1. O sistema (modo seguro)

**Catálogo de produtos (página inicial pública).**



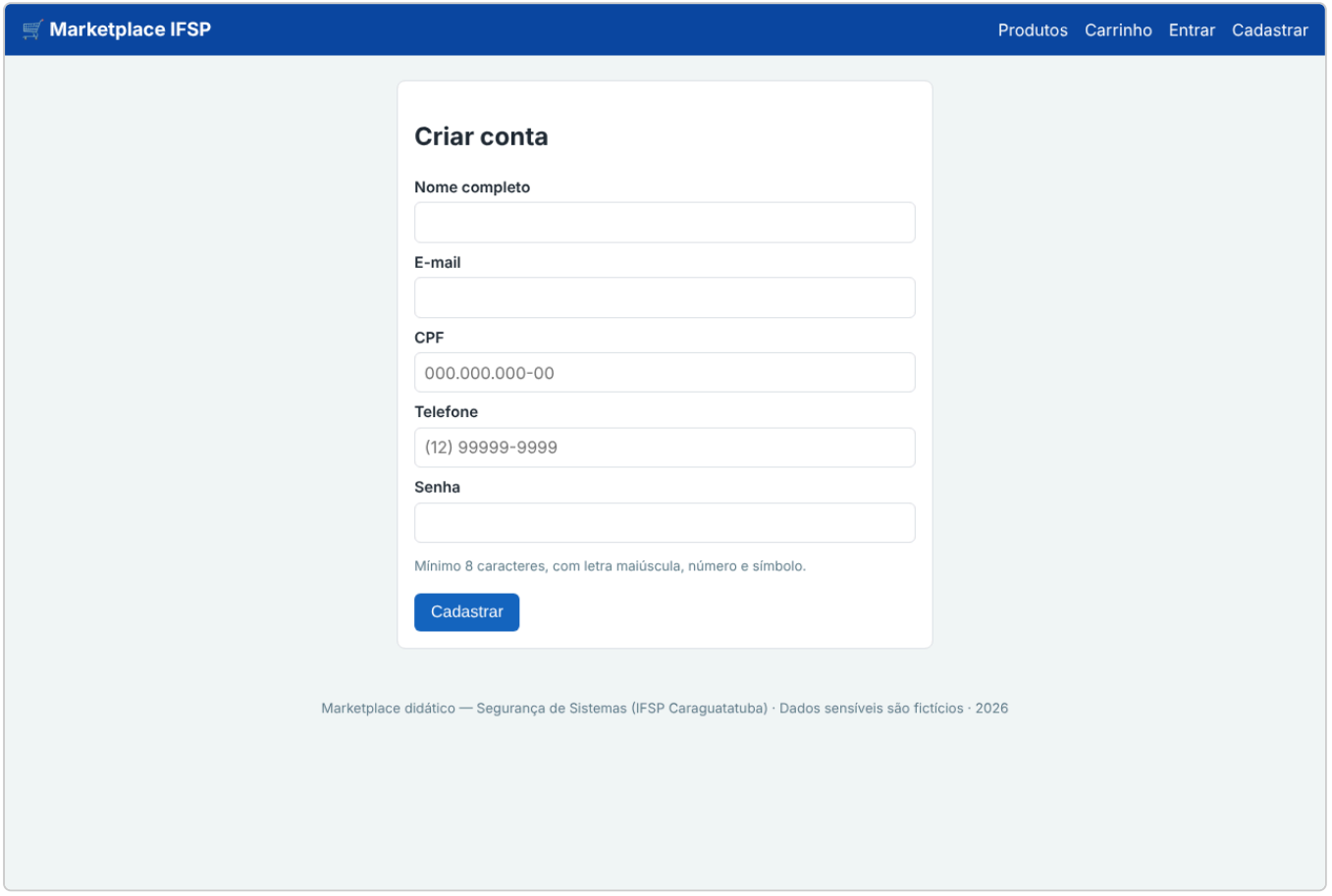

01-catalogo.png

**Tela de login.**



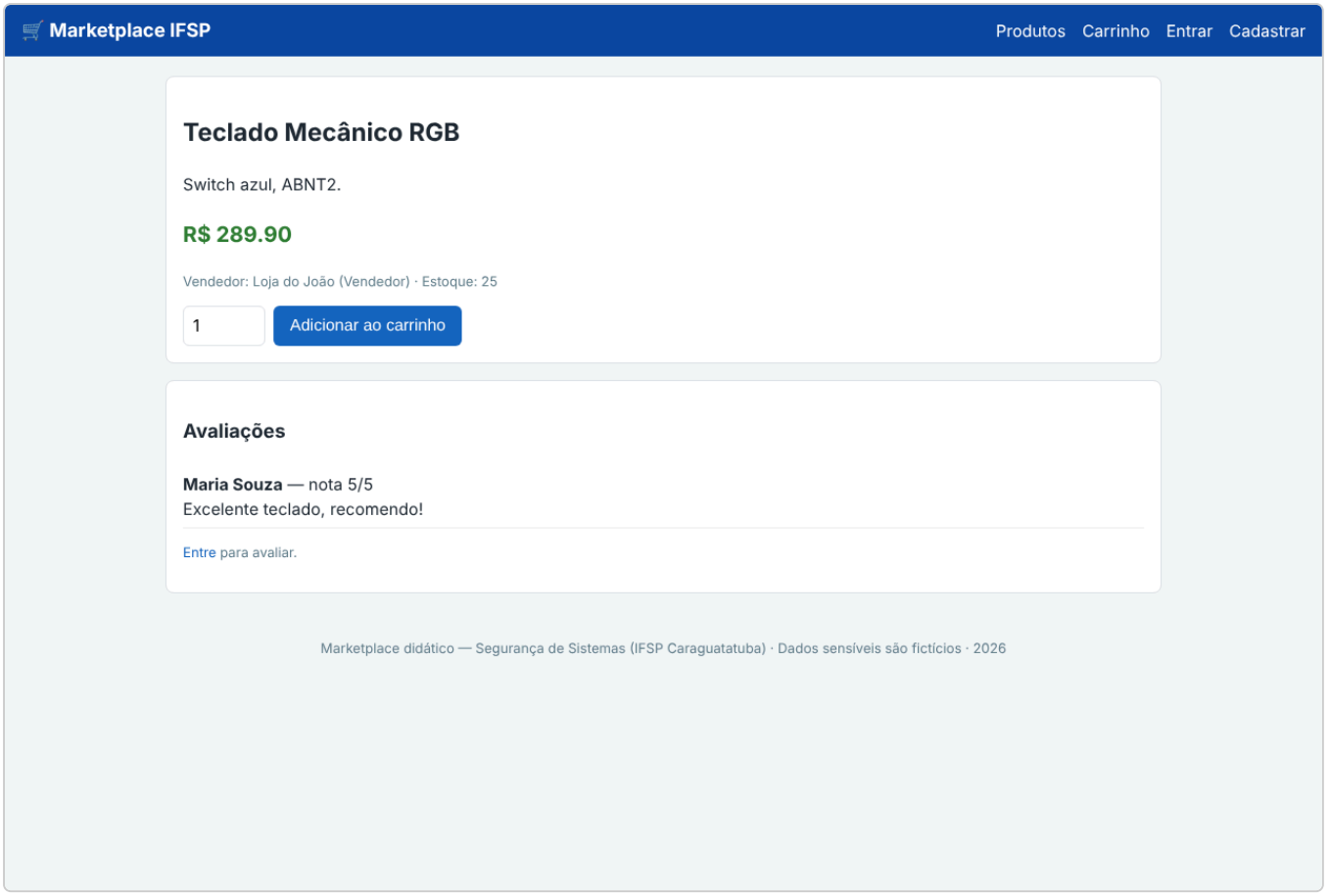

02-login.png

**Cadastro de usuário com política de senha.**



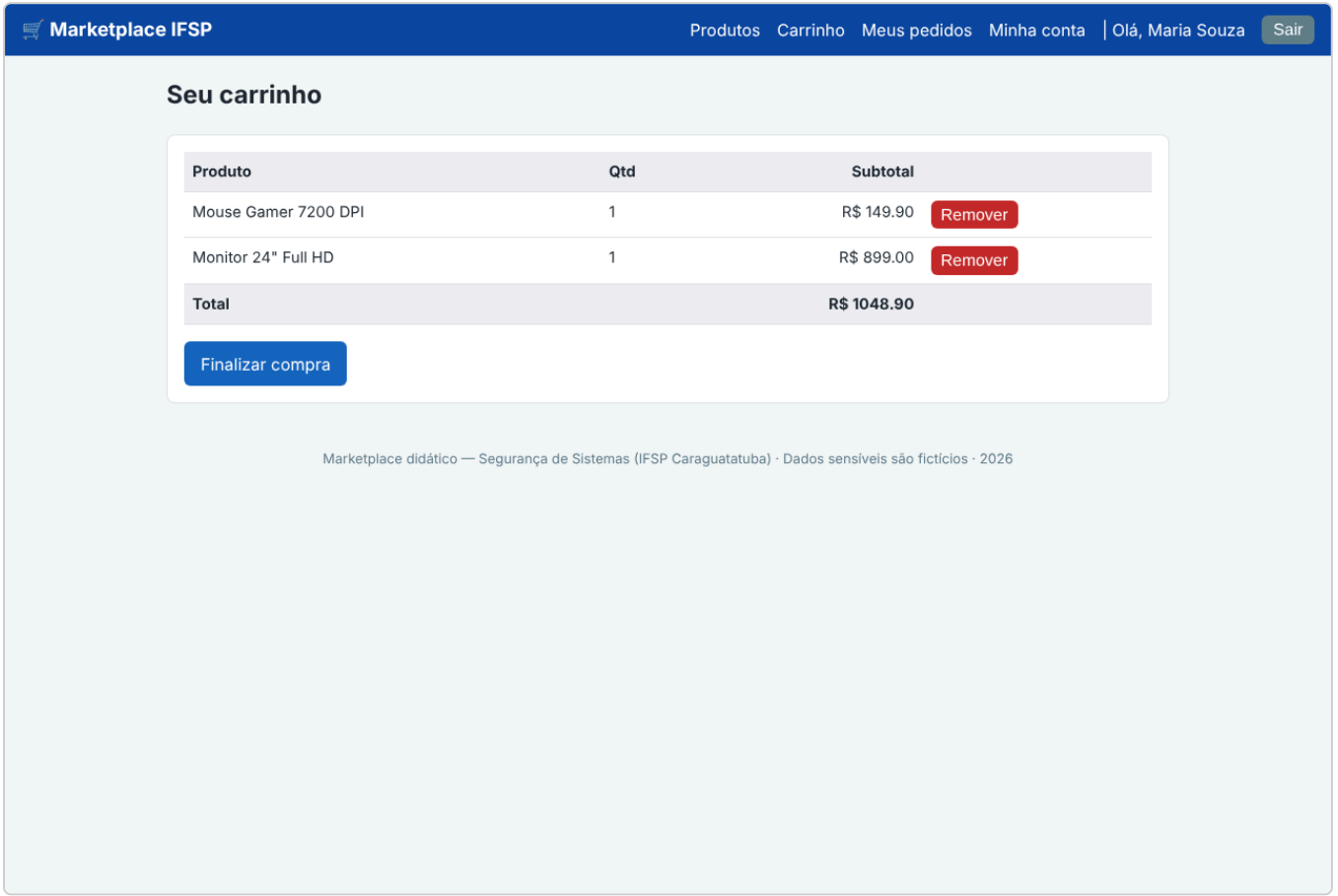

03-cadastro.png

**Página de produto com avaliações.**



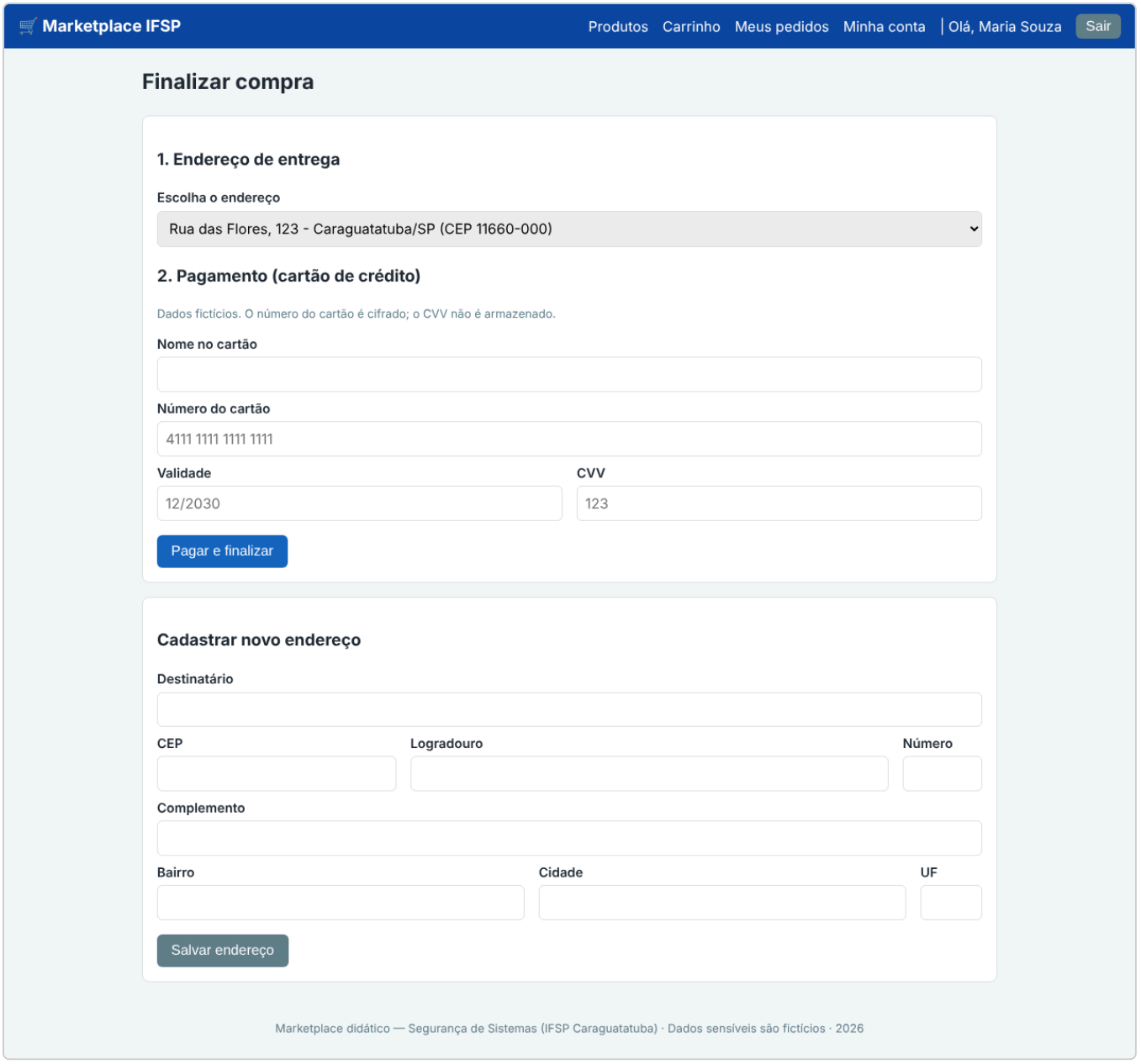

04-produto.png

**Carrinho de compras.**



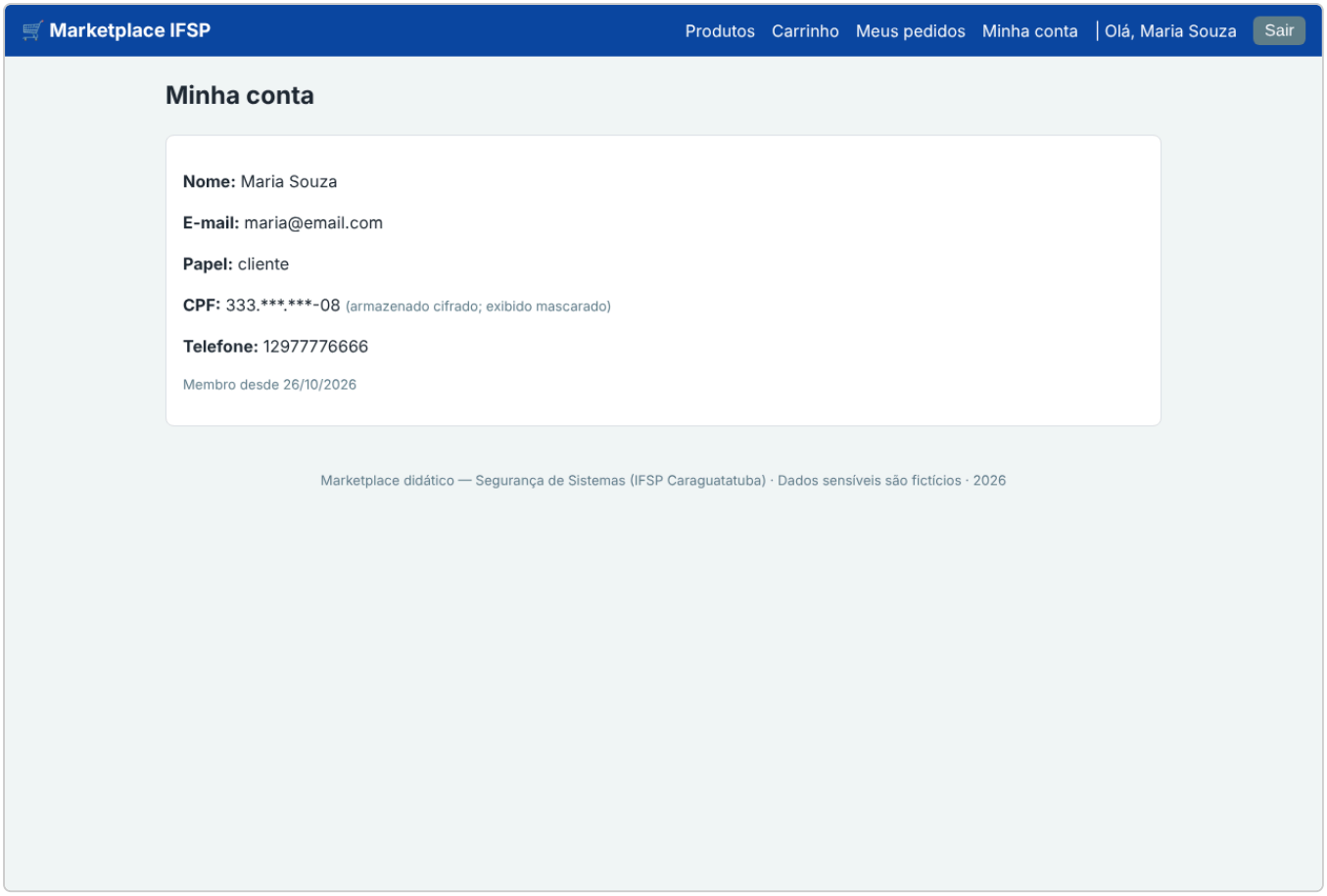

05-carrinho.png

**Checkout: endereço de entrega + pagamento.**



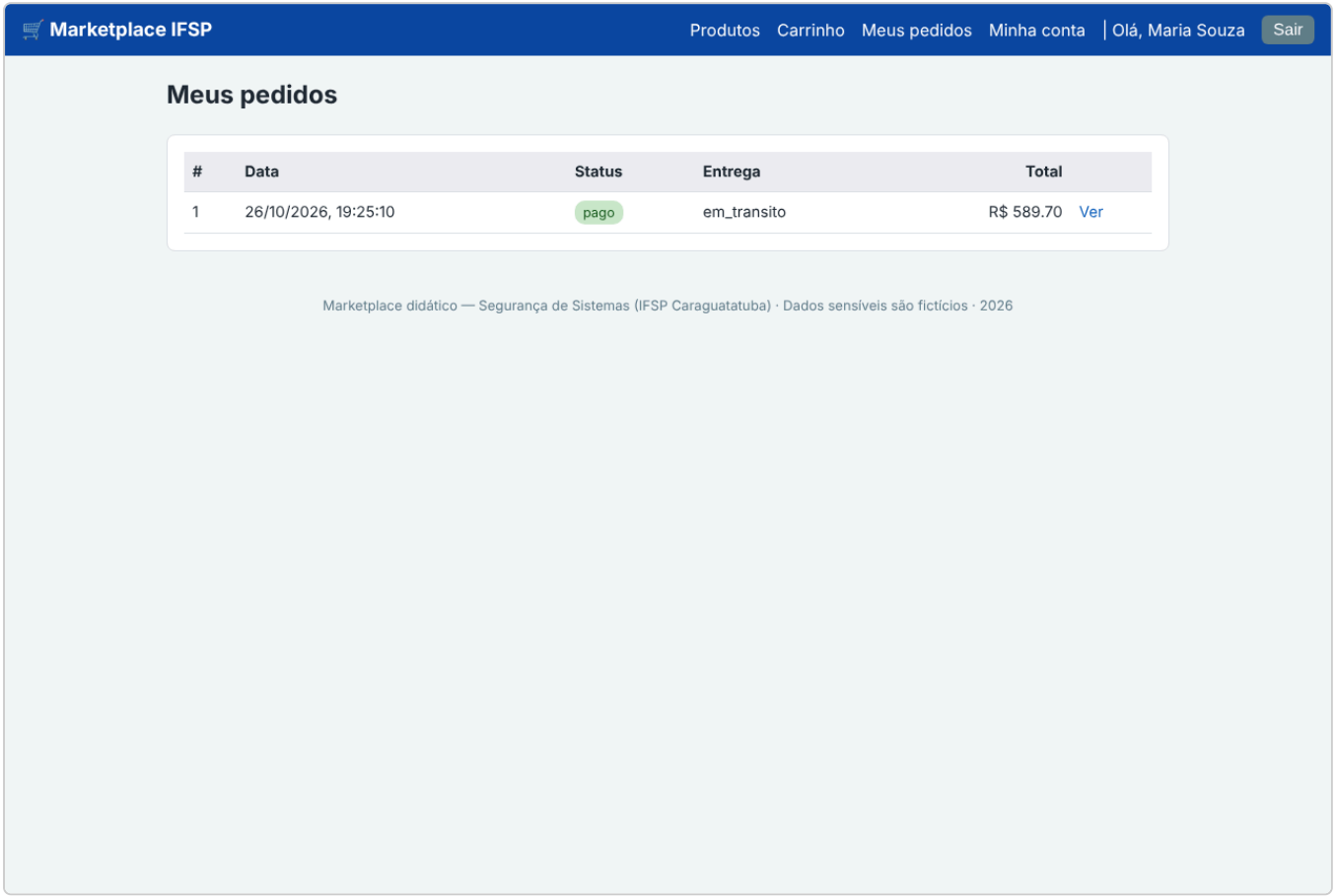

06-checkout.png

**Minha conta: CPF exibido MASCARADO (armazenado cifrado).**



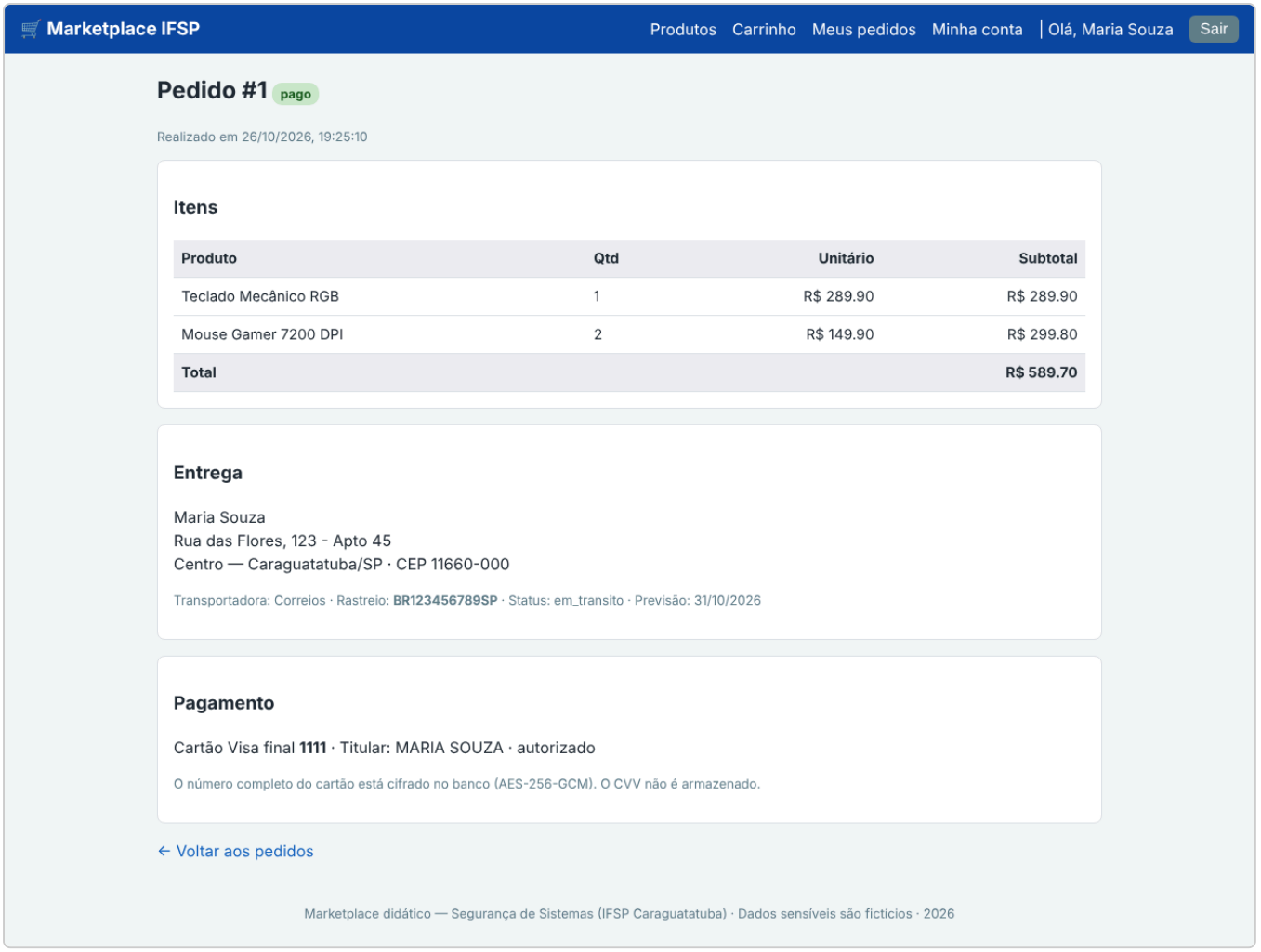

07-conta-dados-sensiveis.png

**Lista de pedidos do usuário.**



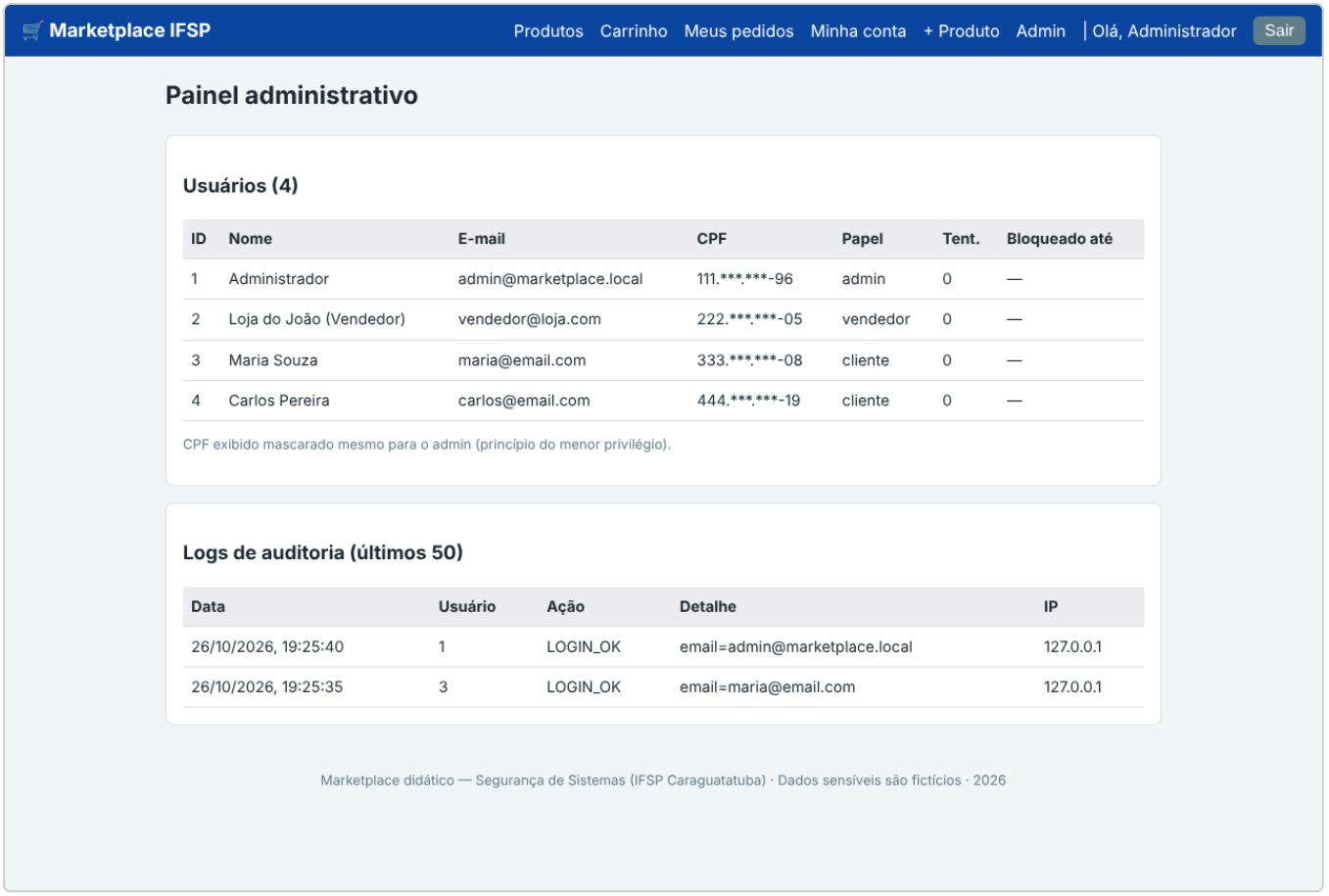

08-meus-pedidos.png

**Detalhe do pedido: itens, entrega e cartão mascarado.**




09-pedido-detalhe.png

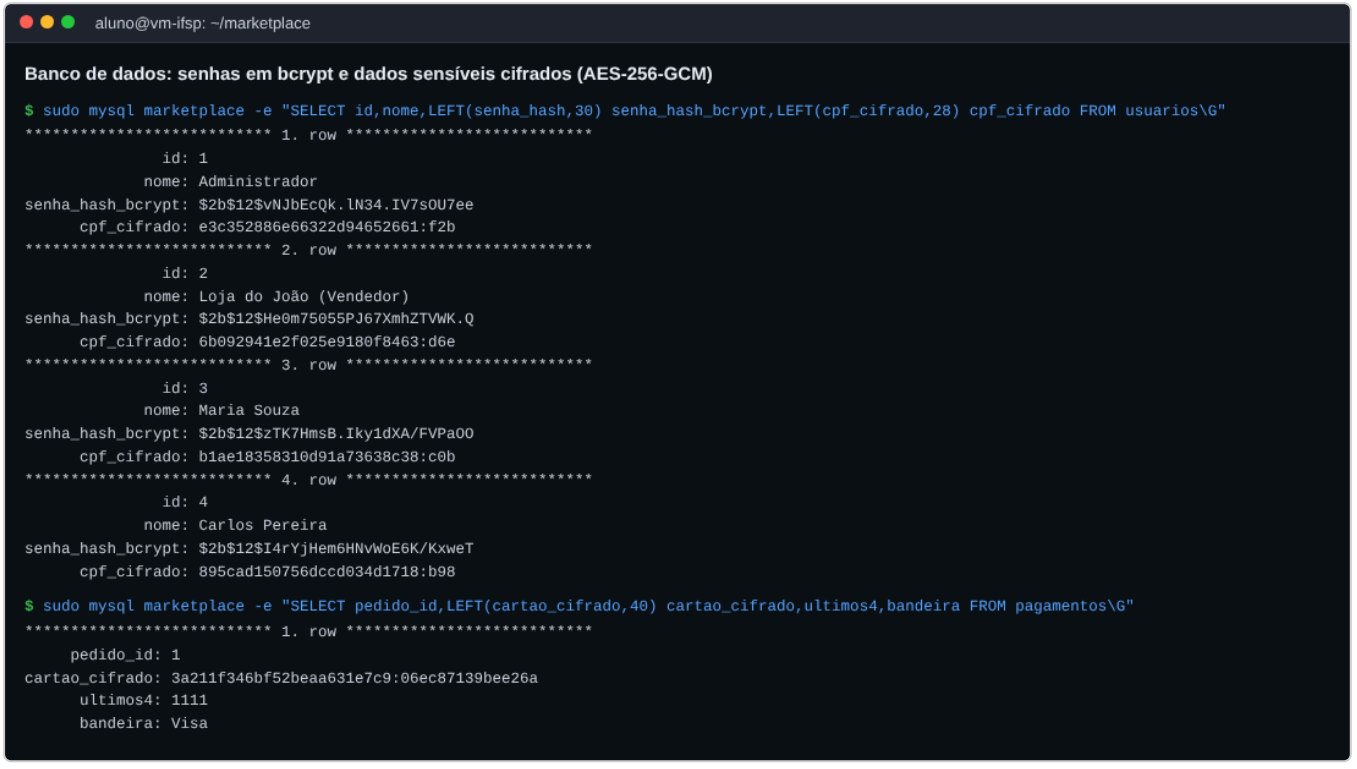
**Painel admin: usuários (CPF mascarado) e logs de auditoria.**




10-admin-usuarios-auditoria.png

## 2. Operações rodando (evidências técnicas — modo seguro)

**Banco: senhas em bcrypt ($2b$12$) e CPF/cartão cifrados (AES-256-GCM) — ilegíveis.**




11-op-banco-dados-cifrados.png

**Tabela logs_auditoria registrando LOGIN_OK e COMPRA com IP.**

aluno@vm-ifsp: ~/marketplace

**Logs de auditoria (OWASP A09) registrando login e compra**

```
$ sudo mysql marketplace -e "SELECT acao,detalhe,ip FROM logs_auditoria ORDER BY id DESC LIMIT 6"
acao    detalhe ip
LOGIN_OK        email=admin@marketplace.local   127.0.0.1
LOGIN_OK        email=maria@email.com   127.0.0.1
```

12-op-auditoria.png

**Teste automatizado: SQLi e IDOR bloqueados (3/3 OK).**

aluno@vm-ifsp: ~/marketplace

**Teste automatizado: SQLi e IDOR bloqueados no modo seguro**

```
$ node tests/pentest.js
Testes de verificação (modo seguro) em http://localhost:3000

  ✓ login válido redireciona (302)
  ✓ SQL injection no login é bloqueado (401)
  ✓ IDOR em pedido alheio é bloqueado (403)

Resultado: 3 ok, 0 falha(s).
```

13-op-teste-automatizado.png

**SQL Injection no login retorna HTTP 401 (ataque falhou).**

aluno@vm-ifsp: ~/marketplace

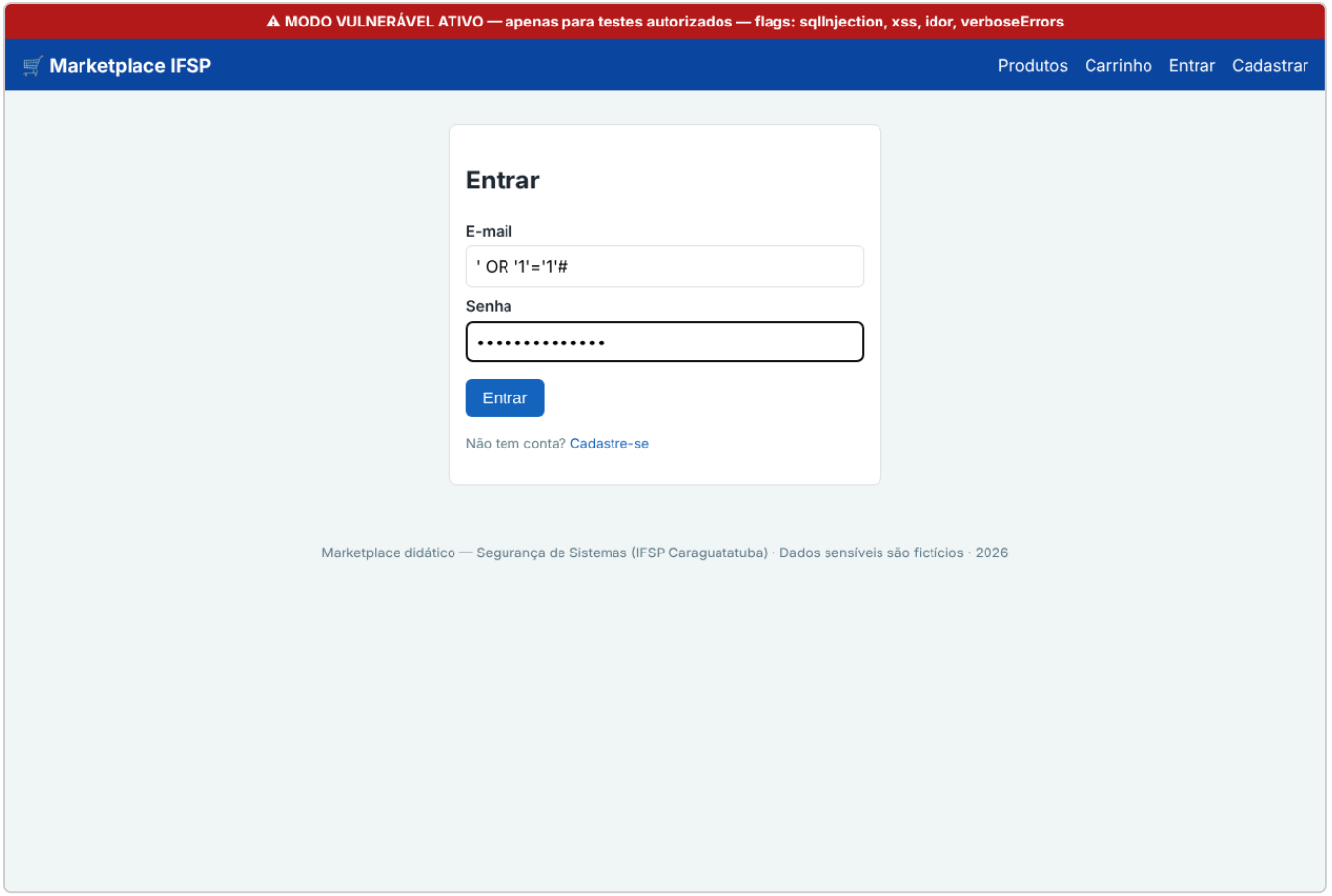
**Modo SEGURO: SQL Injection no login retorna HTTP 401 (bloqueado)**

```
$ curl -s -o /dev/null -w 'HTTP %{http_code}\n' -X POST .../login  --data "email=' OR '1'='1' -- "
resposta: HTTP 429  (401 = ataque falhou)
```

14-op-sqli-bloqueado-seguro.png

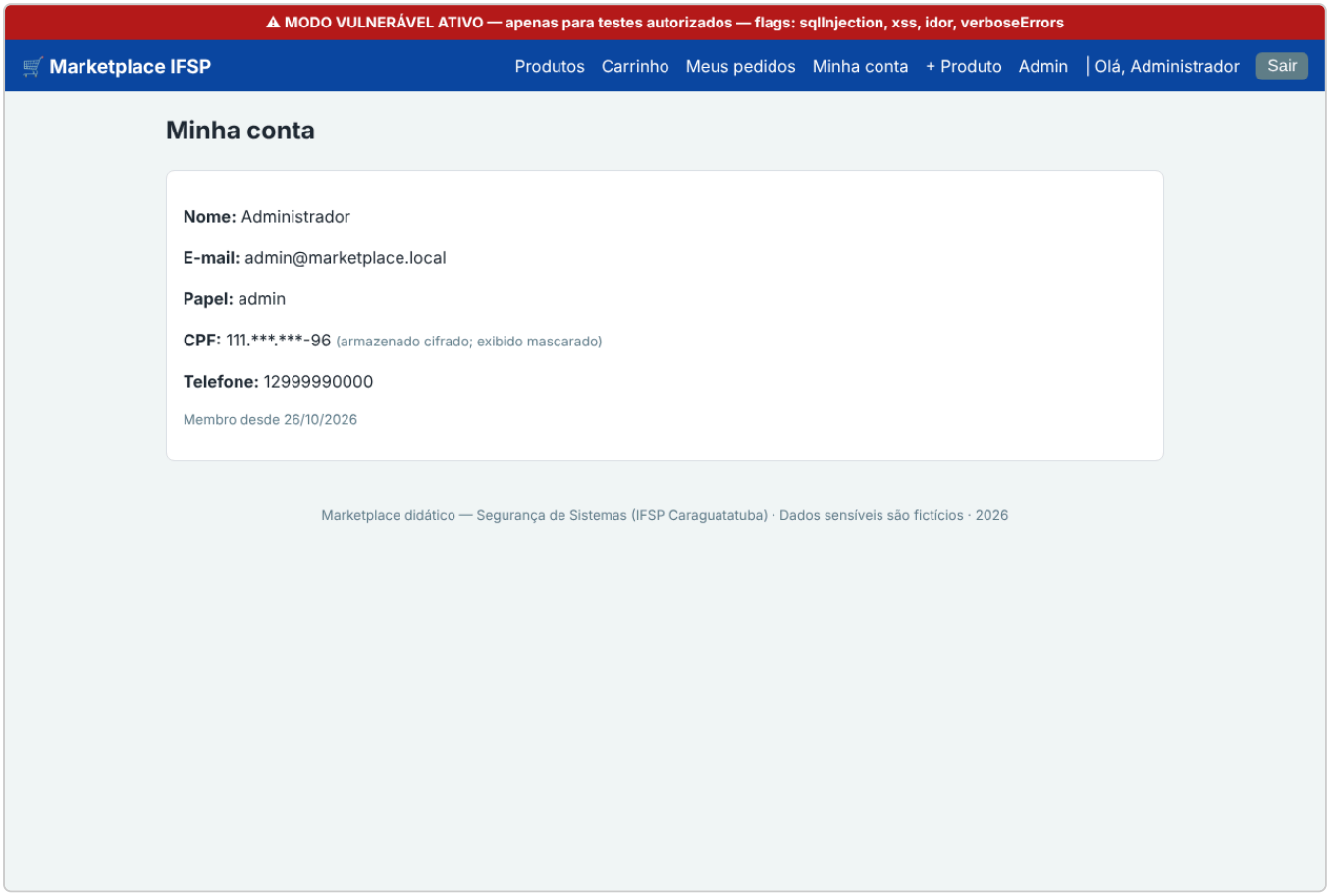
## 3. Ataques BEM-SUCEDIDOS (modo vulnerável — para documentação do pentest)

**SQL Injection: payload ' OR '1'='1'# no campo de e-mail.**



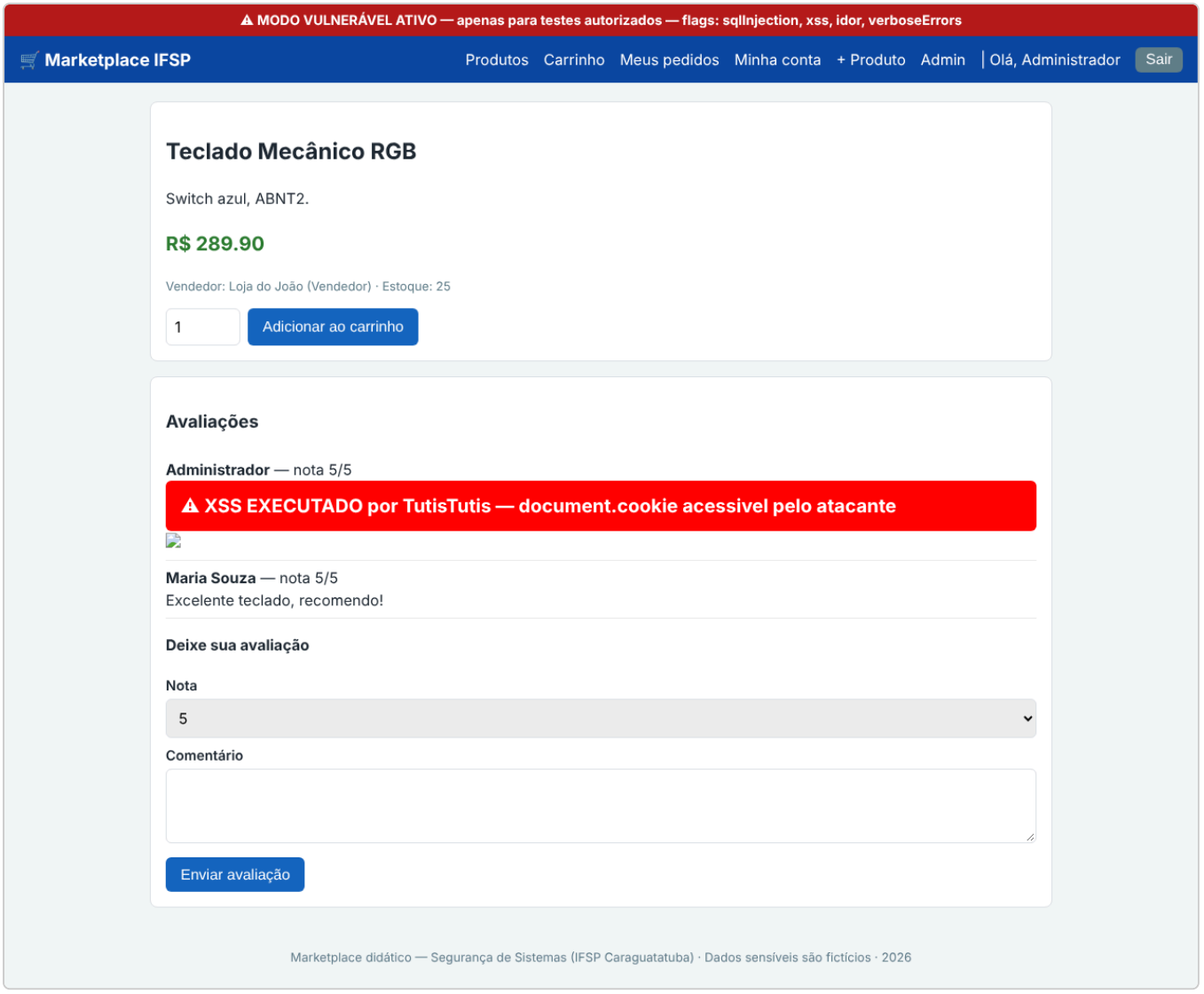

15-ataque-sqli-login-payload.png

**Resultado: autenticado como ADMINISTRADOR sem senha válida.**



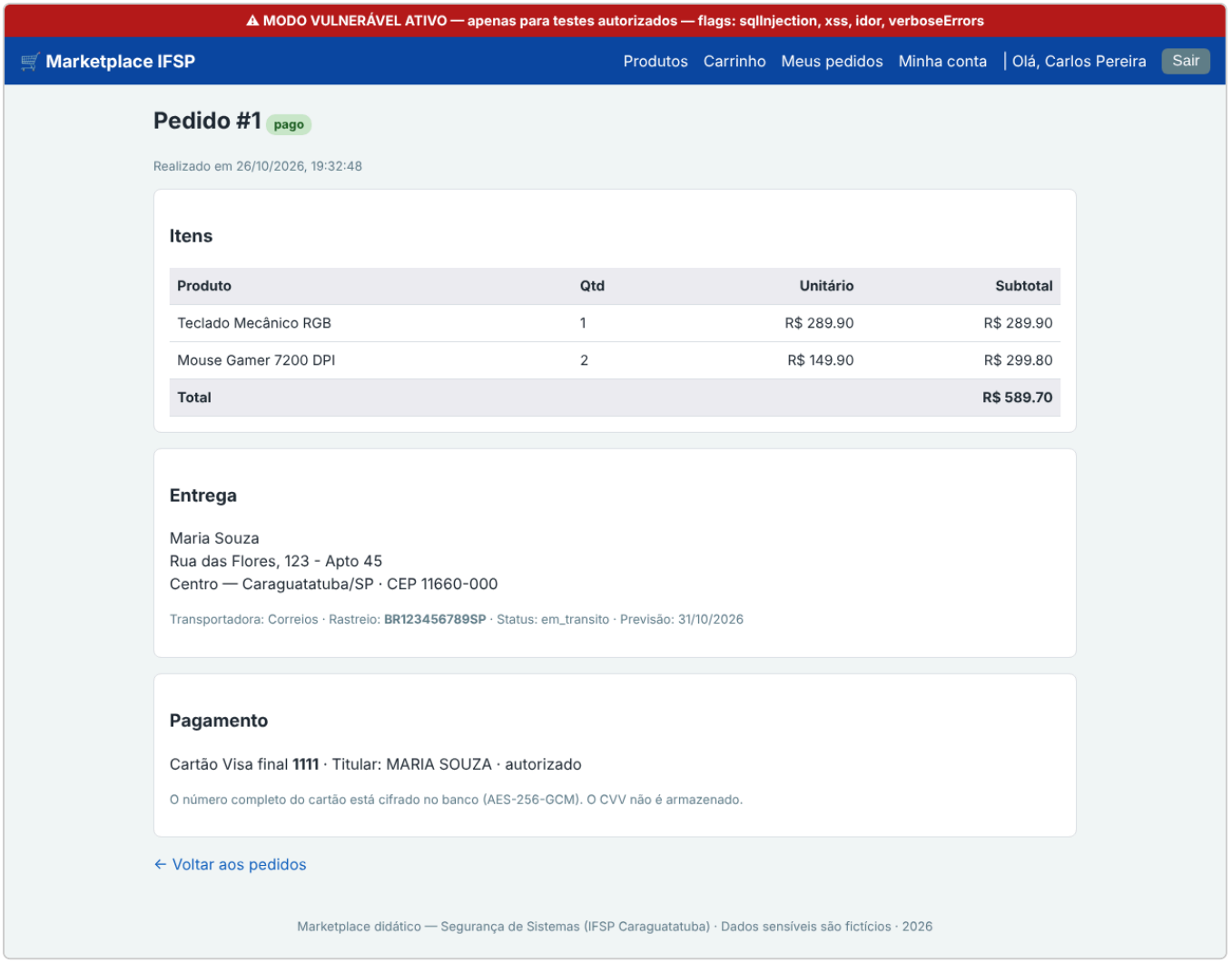

16-ataque-sqli-logado-como-admin.png

**XSS armazenado: script/HTML injetado numa avaliação executa na página.**



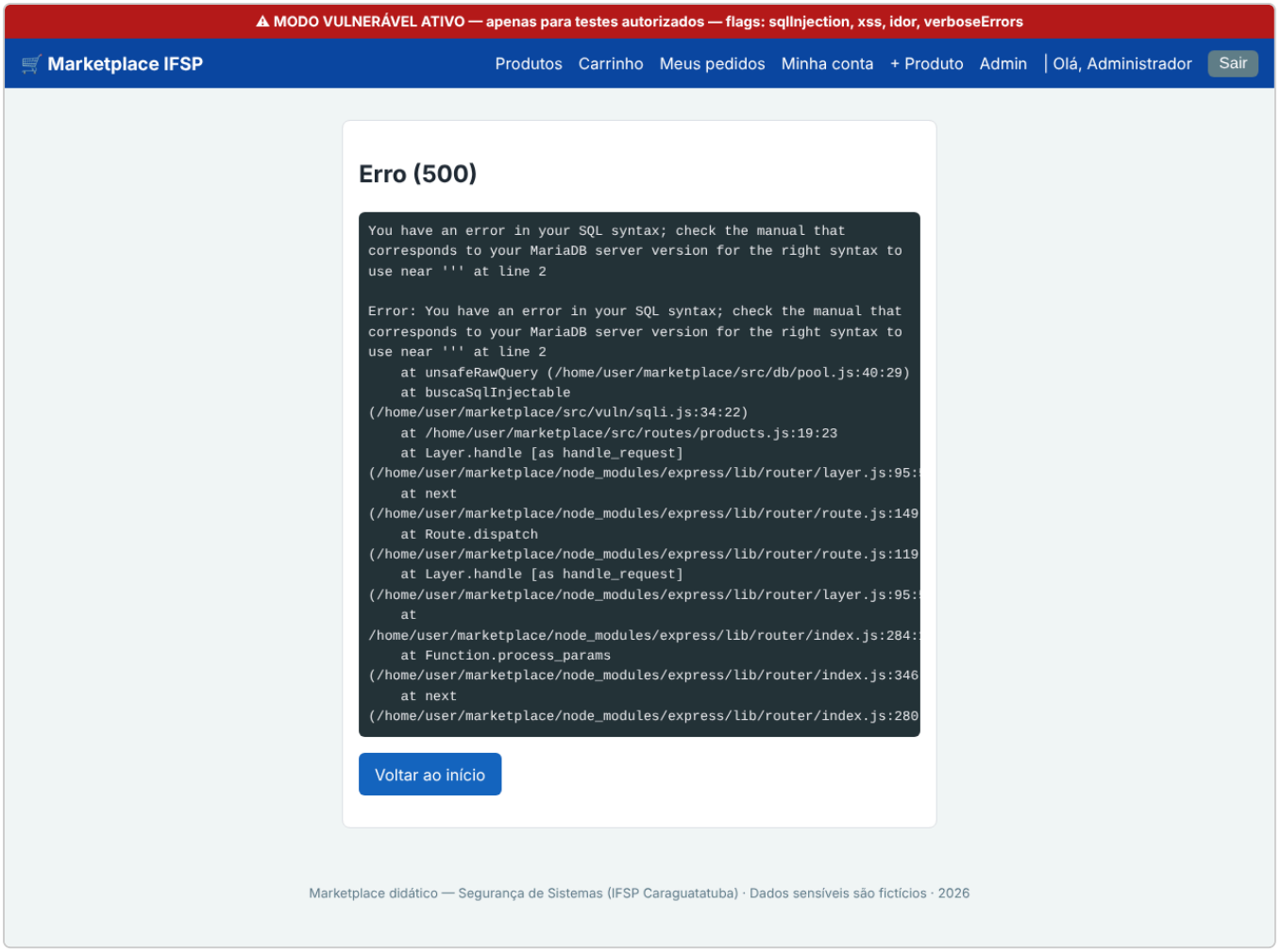

17-ataque-xss-armazenado.png

**IDOR: Carlos (cliente) acessa o pedido da Maria (endereço e cartão dela).**




18-ataque-idor-pedido-alheio.png

**Erro verboso: vaza erro de SQL e stack trace (information disclosure).**




19-ataque-erro-verboso-vaza-sql.png